2025 International Conference on Algorithm, Artificial Intelligence and Computer Vision (AAICV) | 979-8-3315-1470-9/25/$31.00 ©2025 IEEE | DOI: 10.1109/AAICV66571.2025.00040

Construction of graph neural network vulnerability propagation identification mechanism for software supply chain

Sunpei Jian [1*,a]
1. Army Engineering University of PLA, nanjing, Jiangsu,210007,China
[a]Email: 3078991049@qq.com

***Abstract*-With the increasingly prominent software supply chain security problems, how to control the spread of vulnerabilities has become the main task of supply chain security management. This paper proposes a vulnerability propagation identification mechanism utilizing Graph Neural Networks (GNNs), delves into the mechanics of vulnerability propagation, and extracts pivotal features of propagation paths.The GNN model is trained to identify the trend of vulnerability propagation, and the real-time and accuracy of vulnerability detection is improved by combining the automatic early warning system. By optimizing the identification mechanism, such as deepening the level of graph convolutional network (GCN) and integrating self-supervised learning strategies, the accuracy and efficiency of vulnerability propagation detection are improved. This mechanism can effectively identify potential vulnerability propagation paths in the software supply chain, improve vulnerability detection and protection capabilities, and provide intelligent solutions for vulnerability management.**

Key words-software supply chain; Graph neural network; Vulnerability propagation; Information security; Early warning mechanism

I. INTRODUCTION

Currently, the transmission of vulnerabilities within the software supply chain poses a significant threat. Due to the intricate dependencies among components, these vulnerabilities can rapidly proliferate throughout the supply chain, jeopardizing the stability of the entire system. Traditional vulnerability detection methods, which rely on static review and pattern matching, cannot accurately identify the spread trajectory and impact amplitude of vulnerabilities. The graph neural network (GNN) shows its unique ability in constructing complex mathematical models, which provides an intelligent solution for detecting the propagation process of vulnerabilities. This study proposes a framework for vulnerability propagation detection based on GNN technology, discusses the fundamental principle of vulnerability propagation, constructs a propagation dependence graph, and predicts the propagation trend through GNN model, and then designs a set of automatic early warning system to complete the real-time vulnerability detection task, providing a strong technical guarantee for the security of software supply chain.

II. ANALYSIS AND MODELING OF VULNERABILITY PROPAGATION IN SOFTWARE SUPPLY CHAIN

A. Overview of software supply chain security

The software supply chain comprises numerous components, libraries, tools, and services, and its complex dependencies expose it to significant security risks. Open source components are widely used, causing vulnerabilities to spread through dependent networks, affecting downstream systems, and even threatening the entire software ecosystem. Traditional security vulnerability detection techniques, which mainly rely on static review and pattern comparison, cannot accurately track the spread of vulnerabilities and assess their possible impact. With the increase of software system complexity, it is very important to build an efficient vulnerability transmission detection mechanism to maintain the normal operation of software supply chain.

B. Analysis of vulnerability propagation mechanism

Within the software supply chain, the intricate relationship between vulnerability propagation and components can be primarily categorized into direct and indirect propagation. Direct propagation is the direct transmission of a vulnerability from a core component to its closely dependent subcomponents, posing a threat to their security. Indirect communication, on the other hand, involves the hierarchical transmission of multiple dependencies, leading to a broader threat to the entire supply chain ecology. The rate and scope of vulnerability propagation are affected by factors such as the level of dependency, component popularity, and version update. Studying how vulnerabilities propagate helps to accurately predict affected components, optimize vulnerability remediation strategies, and improve the overall security of the software supply chain.

C. Software supply chain vulnerability propagation modeling

The objective of vulnerability propagation modeling in the software supply chain is to analyze the diffusion mechanisms of vulnerabilities within complex supply chains and construct an effective identification and prediction model. In the traditional modeling techniques, topological structure analysis based on propagation path, dependency network analysis and probability propagation are usually used, but these techniques often can not accurately describe the complex nature of the dynamic propagation of vulnerabilities. The graphical neural network (GNN) modeling strategy can more effectively make use of the complex association between software components, and through the fusion of node attributes and edge weight information, the path of vulnerability propagation can be deeply learned and predicted, providing strong data support for the security of the software supply chain.

III. CONSTRUCTION OF VULNERABILITY PROPAGATION IDENTIFICATION MECHANISM BASED ON GRAPH NEURAL NETWORK

979-8-3315-1470-9/25/$31.00 ©2025 IEEE

DOI 10.1109/AAICV66571.2025.00040
Authorized licensed use limited to: Consortium - Saudi Arabia SDL. Downloaded on February 25,2026 at 13:42:37 UTC from IEEE Xplore. Restrictions apply.

A. Construct a supply chain vulnerability propagation dependency graph

Vulnerability propagation in the software supply chain depends on the complex relationships among components $G=(V,E,W)$, It can directly represent the propagation path and impact scope of the vulnerability。In this figure，Per node（V）represents a software component or library，Edge（E）represents dependencies between components，Edge weight（W）it is used to measure the possibility and impact of vulnerability transmission.The attributes of a component include code overlap, security vulnerability records, and security fix status, while the relevance characteristics include call frequency and dependency tightness. The core process of constructing this diagram includes collecting the data of components in the software supply chain and mining the dependencies between them. By analyzing component update history and vulnerability reach, key transmission routes and higher-risk components can be identified. This figure provides the data basis for the subsequent identification of vulnerability propagation based on graph neural network (GNN), and predicts the potential vulnerability propagation risk in practical applications to enhance the security protection of the software supply chain (see Figure 1).

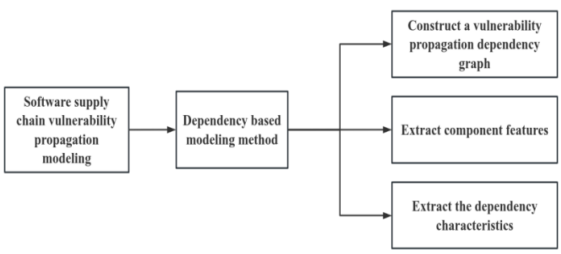

Figure 1. Software supply chain vulnerability propagation modeling frame

B. Training GNN model to identify vulnerability propagation trend

Using graph neural network to identify and predict vulnerability propagation in software supply chain, it can learn the vulnerability propagation mode among different components by using the complex dependency relationship between components.Feature updates via GNN for each component v_i The features in the first l layer are represented as:

$$H_i^{(l+1)}=\sigma\left(\sum_{j\in N(i)}\frac{1}{|N(i)|}W_{ij}H_j^{(l)}W^{(l)}\right) \quad (1)$$

$H_i^{(l)}$ is the component feature of the first l layer, W_{ij} is the propagation weight of the dependency, $W_{(l)}$ is the GNN training parameter, σ is the activation function.During the training process, the model is optimized by minimizing the cross-entropy loss function:

$$L=-\sum_{i=1}^{N}\left[y_i\log\left(\hat{y}_i\right)+(1-y_i)\log\left(1-\hat{y}_i\right)\right] \quad (2)$$

y_i spread tags for real vulnerabilities, $\hat{y}_i$ predict the probability for GNN.Ultimately, the GNN model learns the vulnerability propagation patterns, enables accurate prediction of vulnerability propagation paths, and provides technical support for supply chain security assessments.

C. Design automated vulnerability warning system

Based on the trained graph neural network (GNN) model, an automatic vulnerability early warning system is designed to realize real-time monitoring and risk assessment of vulnerability propagation in software supply chain. The alarm system needs to collect supply chain dependency information, extract components and dependency characteristics, and import them into a trained graph neural network model to calculate the possibility of vulnerability transmission. By combining historical records and time series analysis, you can predict which components may be affected in the future and assess the overall risk of vulnerability transmission. The system continuously monitors the propagation of vulnerabilities and categorizes components based on the extent of their propagation impact. If a high-risk vulnerability is found, the system will automatically start the alarm mechanism, send a notice to the development and operation personnel, and give the corresponding repair plan. In order to enhance the accuracy of vulnerability detection, the system adopts adaptive threshold adjustment strategy to adjust the alarm standard in real time according to the specific environment of different supply chains. The early warning system can also be integrated with enterprise security platforms to automate vulnerability remediation and upgrade defense strategies (see Figure 2).

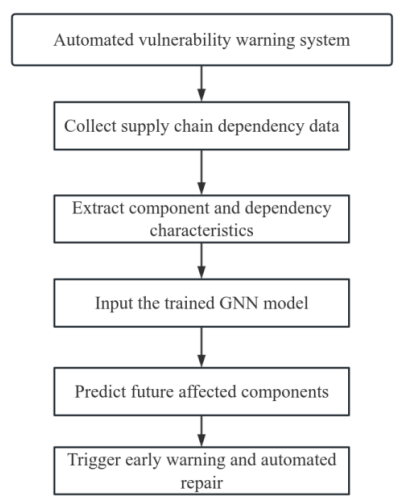

Figure 2 Schematic diagram of automatic vulnerability warning system

IV. MEASURES TO OPTIMIZE THE IDENTIFICATION MECHANISM OF GRAPH NEURAL NETWORK VULNERABILITY PROPAGATION

Authorized licensed use limited to: Consortium - Saudi Arabia SDL. Downloaded on February 25,2026 at 13:42:37 UTC from IEEE Xplore. Restrictions apply.

A. Increase the depth of graph convolutional network and optimize the ability of information transmission

When the depth of the extended graph convolutional network (GCN) is extended, the layer number configuration is optimized, so that the network can effectively capture deep propagation features and avoid over-smoothing features. The cross-layer jump is introduced by the residual connection, which effectively alleviates the problem of gradient disappearance. By implementing the intra-layer normalization strategy, the stability of deep network training is enhanced, and the convergence process of the model is accelerated. The integration of leapfrog knowledge network structure promotes the fusion of multi-level information, so that the model can fully absorb and use different levels of characteristic information. Using multi-scale feature processing strategy, local and global dependencies can be captured synchronously at all levels. At the same time, by using the loss function of contrast learning, the learning process of cross-layer information transmission is optimized and the efficiency of information transmission is improved. In addition, adaptive learning rate adjustment strategy is adopted to avoid training instability caused by network deepening, and AdamW optimization algorithm is introduced to improve the efficiency of parameter updating of deep graph convolutional networks and ensure that vulnerability propagation path information can still be learned stably after increasing the depth. The table describes the optimization measures and effects of extending GCN depth (see Table 1).

TABLE 1 GCN DEPTH OPTIMIZATION MEASURES AND THEIR EFFECTS

Optimization measure	effect
Optimize layer configuration	Capture deep propagation features to avoid oversmoothing features
Use residual connection	Introduce cross-layer jumping to alleviate the problem of gradient disappearance
Intra-layer normalization	Stabilize the training process and accelerate the convergence speed
Leaping knowledge network	Multi-layer information is fused to improve feature utilization
Multi-scale feature processing	Capture local and global dependencies synchronously
Compare the learning loss function	Optimize cross-layer information transfer and improve communication efficiency
Adaptive learning rate adjustment	Prevent training instability and improve convergence
AdamW optimization algorithm	Improve the efficiency of parameter updating and stabilize the deep model

This table lists the optimization measures for extending the depth of the graph Convolutional network (GCN), and the effect of each measure on the model's information transmission ability, including the optimization of the number of layers, residual connection and other methods.

B.Self-supervised learning is introduced to improve the generalization ability of vulnerability propagation detection.

Self-supervised learning is employed to bolster the generalization capability of the vulnerability propagation identification model. A contrastive learning task is devised to differentiate between various vulnerability propagation paths. Positive and negative sample pairs are generated to enable the model to learn the similarity and difference of propagation modes. Positive samples are composed of components of the same transmission path, while negative samples are derived from components of different paths, and self-supervised loss is further optimized. Implement diversified data enhancement strategies, such as adjusting node weights, changing the frequency of component use, etc., and construct different versions of dependency graphs to adapt to different situations. The node attribute prediction training is carried out, and the characteristics of some components are hidden during the training stage, so that GNN learns how to recover the missing information, thus improving the model toughness. Combined with subgraph structure reconstruction technology, the study of vulnerability propagation structure is strengthened through coding and decoding. Balance the loss ratio between the self-supervised task and the main task, enhance the promoting role of the self-supervised task in vulnerability propagation detection, and make the model have high generalization ability in the low-labeled data scenario.

C.Using graph pooling to reduce computational redundancy

Upon applying Graph Pooling, an appropriate dimensionality reduction strategy is adopted to alleviate the computational burden of the model while preserving the core information pertinent to vulnerability propagation. The attention-based pooling method calculates the importance score of nodes, screens out the key propagation nodes, and eliminates the nodes with less contribution to simplify the computing burden. An evaluation node quantization function is constructed, which considers the breadth of vulnerability propagation and the frequency of use of modules, and sets up a dynamically adjusted threshold to achieve node screening. The layered pooling strategy is adopted to subdivide the dependency diagram of the supply chain into several parts, and each part is independently pooled to reduce the overall computing burden and maintain the accuracy of local information dissemination. In the global scope, maximum pooling or weighted average pooling technology is applied to extract the global characteristics of vulnerability propagation. Combined with graph convolutional network embedding technology, the integrity of vulnerability propagation path information is guaranteed while reducing the computation. Improve the pooling node connection mode to avoid information loss, thus improving detection accuracy and operation efficiency.

V. CONCLUSION

This paper focuses on the problem of vulnerability propagation in software supply chain, builds a vulnerability propagation identification mechanism based on graph neural network, establishes vulnerability propagation dependence graph, trains GNN model to learn vulnerability propagation mode, and combines with automatic early warning system to improve vulnerability propagation detection ability. Optimize the detection mechanism, increase the depth of GCN, introduce self-supervised learning, and improve the

Authorized licensed use limited to: Consortium - Saudi Arabia SDL. Downloaded on February 25,2026 at 13:42:37 UTC from IEEE Xplore. Restrictions apply.

recognition accuracy and calculation efficiency of the model. Future research could further integrate time series analysis and federated learning to enhance the dynamic adaptability of vulnerability propagation detection, bolster privacy protection capabilities, and ultimately strengthen the security protection of the software supply chain.

ACKNOWLEDGMENTS

In the process of the completion of this study, I got a lot of help. I would like to express my sincere thanks to my supervisor for his valuable advice on the research direction and thesis creation. In addition, I would like to express my gratitude to the students in the research team for their help in the design of the experiment and the communication of skills. Furthermore, I extend my gratitude to the institutions that have provided invaluable research materials and data support. Finally, I would like to express my gratitude to my family and friends for their tolerance and encouragement, which made it possible for me to complete this thesis successfully.

REFERENCE

[1] Algarin A B , Werb D ,Shumskaya, NatalyaKurmanalieva, AinuraBlyum, AnnaCepeda, JavierPatterson, Thomas L.Baral, StefanSmith, Laramie R.Financial Vulnerability and Its Association with HIV Transmission Risk Behaviors Among People Who Inject Drugs in Kyrgyzstan[J].AIDS and behavior, 2024, 28(1):310-319.

[2] Vasudeva A , Sood M .On the vulnerability of the mobile ad hoc network to transmission power controlled Sybil attack: Adopting the mobility-based clustering[J].Journal of King Saud University - Computer and Information Sciences, 2022, 34(9):7025-7044.

[3] Sun Y , Xie B , Wang S ,et al.Dynamic Assessment of Road Network Vulnerability Based on Cell Transmission Model[J].Journal of Advanced Transportation, 2021, 2021(1872):1-14.

[4] Massacci F , Williams L .Software Supply Chain Security [Guest Editors' Introduction][J].IEEE security & privacy, 2023(6):21.

[5] Sunny J , Pillai V M , Nath H V ,et al.Blockchain-enabled beer game: a software tool for familiarizing the application of blockchain in supply chain management[J].Industrial management & data systems, 2022(4):122.

[6] Greenfield D .Amazon Now Offers Supply Chain Software[J].Automation World, 2023, 21(1).

Authorized licensed use limited to: Consortium - Saudi Arabia SDL. Downloaded on February 25,2026 at 13:42:37 UTC from IEEE Xplore. Restrictions apply.